

Infrastructure as a Battlefield

Zero Days, Critical Infrastructure, and Responsible Active Defense

Socio Technical Impact Analysis of Nicole Perlroth's *This Is How They Tell Me the World Ends*

Elaborado por

Pablo Alvarado Andrés Proaño Roberto Villafuertes

Colegio de Ciencias e Ingenierías

Curso: CMP 5006 Seguridad Informática

Informe académico sobre vulnerabilidades de día cero, sistemas industriales, riesgo geopolítico y defensa activa responsable en infraestructura crítica.

Índice

Resumen Ejecutivo	3
1. Introducción: infraestructura como campo de batalla	3
2. Zero days: de error técnico a activo militar	3
3. Technical Breakdown: PLCs, HMI y deuda de seguridad OT	5
4. Casos clave: Aurora, Stuxnet, Ucrania, Shadow Brokers y NotPetya	7
5. Societal Impact: ley, percepción pública y comportamiento corporativo	9
6. Policy Framework: Responsible Active Defense	9
7. Personal Critique: ética profesional en InfoSec	12
8. Conclusión	12

Resumen Ejecutivo

Este informe analiza *This Is How They Tell Me the World Ends*, de Nicole Perlroth, desde una pregunta central: ¿cómo una vulnerabilidad digital puede convertirse en amenaza para servicios esenciales como electricidad, agua, transporte, salud y logística? La tesis es que la infraestructura crítica se convierte en campo de batalla cuando convergen tres factores: el mercado de zero days, la acumulación estatal de capacidades ofensivas y la dependencia de sistemas industriales heredados diseñados para continuidad, no para conflicto cibernético.

Perlroth muestra que los zero days no son simples errores de programación. En manos de brokers, contratistas, agencias de inteligencia o gobiernos, una falla desconocida puede transformarse en herramienta de espionaje, vigilancia o sabotaje. Esa dinámica crea una tensión ética: mientras más tiempo se conserva una vulnerabilidad en secreto, mayor es su valor ofensivo, pero también mayor es la exposición de usuarios, empresas e infraestructura civil.

El informe desarrolla tres líneas de análisis. Primero, explica el mercado de zero days y la forma en que una falla técnica puede convertirse en activo militar o comercial. Segundo, analiza tecnologías industriales como PLCs, HMIs, SCADA y sistemas OT para mostrar por qué la infraestructura heredada acumula deuda de seguridad. Tercero, estudia casos como *Operation Aurora*, Stuxnet, Ucrania, Shadow Brokers y NotPetya para evaluar impacto social, cambios institucionales y límites de la defensa activa.

Como respuesta, se propone un marco de *Responsible Active Defense*. Esta defensa activa no equivale a *hack back* ni a represalia privada. Consiste en gobernanza, inventario de activos críticos, segmentación IT/OT, monitoreo autorizado, detección temprana, divulgación responsable, coordinación público privada y recuperación operacional. El objetivo no es atacar al atacante, sino impedir que una intrusión digital se convierta en apagón, interrupción hospitalaria, crisis logística o pérdida de confianza pública.

1. Introducción: infraestructura como campo de batalla

Nicole Perlroth abre *This Is How They Tell Me the World Ends* con Ucrania como advertencia. En el prólogo, las operaciones cibernéticas dejan de ser abstractas y empiezan a afectar electricidad, transporte, agencias públicas, sistemas financieros, empresas y confianza social. La escena de Kyiv plantea la premisa central del libro: cuando una red eléctrica puede apagarse por medios digitales, la ciberseguridad deja de ser solo un problema técnico y se convierte en una cuestión de seguridad pública. [1]

La infraestructura crítica contemporánea depende de sistemas digitales que controlan procesos físicos: redes eléctricas, plantas de agua, hospitales, transporte, manufactura, petróleo, gas y logística. Muchos de esos sistemas fueron diseñados para estabilidad, disponibilidad y continuidad operacional, no para resistir adversarios estatales, mercados de exploits ni campañas de sabotaje. Su fragilidad no surge únicamente de fallas técnicas, sino de la combinación entre tecnología heredada, incentivos económicos, decisiones estatales y dependencia social.

El concepto central es la deuda de seguridad. En entornos industriales, esta deuda aparece cuando equipos antiguos siguen operando durante décadas, cuando los parches se retrasan para no interrumpir procesos, cuando existen protocolos diseñados bajo supuestos de confianza, cuando la segmentación IT/OT es débil o cuando el acceso remoto de proveedores se vuelve indispensable. Cada decisión puede parecer razonable por separado, pero acumulada crea una superficie de ataque que conecta software con consecuencias físicas.

La pregunta guía del informe es la siguiente: ¿cómo transforman los zero days, la deuda de seguridad industrial y la militarización del código a la infraestructura crítica en un campo de batalla, y qué marco de *Responsible Active Defense* puede proteger servicios esenciales sin normalizar represalias privadas ni una carrera ofensiva sin control?

2. Zero days: de error técnico a activo militar

El primer paso para entender la infraestructura como campo de batalla es analizar cómo una vulnerabilidad deja de ser un error técnico y se convierte en un activo estratégico. En *This Is How They Tell Me the World Ends*, Perlroth presenta los zero days como objetos de valor dentro de una economía opaca donde participan hackers, brokers, contratistas, agencias de inteligencia y gobiernos. Un zero day es una falla de software o hardware para la cual todavía no existe defensa disponible. Mientras el proveedor no conozca la falla, no exista parche y los usuarios no hayan actualizado sus sistemas, quien controla el exploit posee una ventaja invisible. [1]

Desde una perspectiva técnica, conviene distinguir tres conceptos. La vulnerabilidad es la falla que permite un

comportamiento no previsto. El exploit es el método o código que aprovecha esa falla. El payload es la acción ejecutada después del acceso, como espionaje, vigilancia, interrupción, sabotaje o persistencia. Esta distinción importa porque el mercado descrito por Perlroth no vende solo conocimiento abstracto: en muchos casos vende capacidades listas para integrarse en operaciones reales.

Concepto	Definición operativa	Implicación ética
Vulnerabilidad zero day	Falla desconocida públicamente o sin parche disponible	Mantenerla secreta prolonga la exposición de usuarios y sistemas civiles
Exploit	Técnica o código que permite aprovechar la falla	Convierte un error técnico en capacidad operacional
Payload	Acción posterior al acceso inicial	Determina si el uso será espionaje, vigilancia, interrupción o sabotaje
Stockpiling	Retención de vulnerabilidades por valor ofensivo	Puede beneficiar a una agencia, pero deja vulnerable al ecosistema completo
Disclosure	Comunicación de la falla para que sea corregida	Reduce el valor ofensivo, pero aumenta la seguridad colectiva

Tabla 1: Diferencia entre vulnerabilidad, exploit y decisión ética.

El problema central es que distintos actores asignan valor diferente a la misma falla. Para un proveedor, la vulnerabilidad es un defecto que debe corregirse. Para un investigador defensivo, es una oportunidad de proteger usuarios. Para un broker, es una mercancía. Para una agencia de inteligencia, puede ser una vía de acceso. Para un gobierno, puede convertirse en una herramienta de espionaje o preparación militar. La misma pieza de conocimiento puede cerrar una puerta o mantenerla abierta deliberadamente.

La escena de *The Fucking Salmon* condensa el dilema moral del libro. Perlroth presenta a vendedores de exploits junto a especialistas preocupados por la seguridad de sistemas industriales. La tensión aparece cuando la pregunta deja de ser si una vulnerabilidad funciona y pasa a ser quién la compra, contra quién será usada y qué infraestructura podría quedar expuesta. La evasión de esa pregunta muestra una característica estructural del mercado: muchos participantes prefieren tratar el exploit como producto y no como responsabilidad.

En *The Cowboy*, *The First Broker* y *Zero Day Charlie*, Perlroth amplía esa tensión al mostrar que los gobiernos no son solo reguladores del mercado, sino también compradores. Esto cambia el equilibrio moral de la ciberseguridad. Un Estado puede tener razones legítimas para buscar capacidades de inteligencia, pero también puede crear incentivos para no reportar fallas que afectan tecnologías usadas por civiles, empresas e infraestructura crítica. Cuando el comprador es una agencia estatal, el zero day deja de ser solo mercancía y pasa a formar parte de una lógica de poder.

El mercado de zero days transforma el significado de una vulnerabilidad: deja de ser únicamente un error que debe corregirse y pasa a ser un recurso que puede venderse, acumularse, ocultarse o usar como arma.

La práctica de *stockpiling* es especialmente problemática. Retener una vulnerabilidad puede parecer útil para operaciones de inteligencia, pero esa utilidad depende de que la falla siga abierta. En software globalizado, una vulnerabilidad en un sistema operativo, router, firewall, aplicación móvil o software industrial no afecta solo al adversario extranjero. También puede afectar hospitales, empresas, gobiernos locales, operadores eléctricos, plantas de agua y ciudadanos comunes. Esta es una de las paradojas principales del libro: el mismo arsenal que promete ventaja ofensiva puede regresar como riesgo doméstico si se filtra, se roba o se reutiliza.

Por eso, el debate sobre responsable disclosure y el *Vulnerabilities Equities Process* es central. El VEP busca evaluar cuándo una vulnerabilidad debe divulgarse para que sea corregida y cuándo podría retenerse temporalmente por razones de seguridad nacional o aplicación de la ley. [2] El proceso no elimina el dilema, pero reconoce que guardar una falla no puede depender solo del interés ofensivo de una agencia. Debe considerar daño potencial, alcance de la tecnología afectada, probabilidad de descubrimiento por terceros, impacto en infraestructura crítica y consecuencias para usuarios civiles.

En infraestructura crítica, la presunción ética debería inclinarse hacia la divulgación responsable. Si una falla puede afectar electricidad, agua, transporte, salud o cadenas logísticas, retenerla implica trasladar riesgo a personas que no participaron en la decisión. Además, los entornos industriales suelen tener ciclos de vida largos y ventanas limitadas de mantenimiento. Eso significa que una vulnerabilidad no corregida puede permanecer activa durante años en

sistemas difíciles de reemplazar o parchear.

En conclusión, Perlroth muestra que los zero days ocupan una posición ambigua entre investigación, comercio y guerra. Su valor proviene de una asimetría de conocimiento: unos pocos saben cómo entrar, mientras los demás creen estar protegidos. Para infraestructura crítica, esa asimetría es inaceptable cuando puede afectar servicios esenciales. Por eso, la gestión de vulnerabilidades debe evaluarse no solo por utilidad ofensiva o beneficio económico, sino por impacto colectivo.

3. Technical Breakdown: PLCs, HMI y deuda de seguridad OT

Para entender por qué la infraestructura crítica es frágil, primero hay que distinguir entre IT y OT. En una red corporativa tradicional, la prioridad suele ser proteger datos, aplicaciones, credenciales y servicios digitales. En tecnología operacional, la prioridad es mantener procesos físicos seguros y disponibles. Esta diferencia cambia el significado de un incidente: en IT, una intrusión puede exponer información; en OT, puede alterar electricidad, presión, temperatura, flujo de agua, maquinaria o transporte.

Los *Industrial Control Systems* permiten monitorear y controlar procesos industriales en sectores como energía, agua, transporte, manufactura, salud, petróleo y gas. [3] Dentro de ese ecosistema aparecen SCADA, PLCs, HMIs, estaciones de ingeniería y redes OT. Estos componentes no existen solo para procesar información, sino para traducir instrucciones digitales en acciones físicas.

La primera tecnología clave es el PLC, o *Programmable Logic Controller*. Un PLC ejecuta lógica de control sobre equipos físicos como motores, bombas, válvulas, sensores, breakers, cintas transportadoras o centrifugadoras. Perlroth muestra su importancia al explicar Stuxnet y Olympic Games: el malware buscaba sistemas con Siemens Step 7, el software usado para programar y monitorear PLCs Siemens. Una vez que encontraba ese entorno, podía llegar a controladores industriales que gobernaban rotores de centrifugadoras. [1]

La lección técnica de Stuxnet es que una estación de ingeniería puede convertirse en puente entre malware común y manipulación física. El atacante no necesita destruir una planta desde afuera si logra modificar la lógica que controla sus equipos. Por eso, el riesgo no está solo en el PLC final, sino en toda la cadena que permite llegar a él: credenciales, estaciones de ingeniería, bases de datos, software industrial, tráfico entre redes y confianza del operador.

La segunda tecnología clave es el HMI, o *Human Machine Interface*. Un HMI permite a operadores humanos observar variables industriales y enviar comandos. En una planta de agua, puede mostrar niveles, presión, bombas y válvulas. En una red eléctrica, puede mostrar estados de interruptores, subestaciones y flujos de energía. Su valor socio técnico está en que conecta mediciones digitales con decisiones humanas. Si un atacante manipula el HMI, no solo altera datos; altera la percepción del operador.

Perlroth conecta este riesgo con GE Cimplicity. En su relato sobre Sandworm, describe archivos industriales usados por General Electric Cimplicity, una plataforma HMI empleada por ingenieros para revisar PLCs que controlaban instalaciones de agua, electricidad, transporte y oleoductos o gasoductos. [1] Este detalle evidencia que los atacantes no buscaban únicamente correos o documentos, sino archivos asociados a ingeniería industrial y operación física.

Tecnología del libro	Rol técnico	Lección para infraestructura crítica
Siemens Step 7 y PLCs	Programación y monitoreo de controladores industriales	Comprometer la capa de ingeniería puede permitir manipular procesos físicos
GE Cimplicity y HMI	Visualización y supervisión de procesos industriales	Manipular la interfaz puede afectar la percepción y decisiones del operador
Protocolos industriales heredados	Comunicación entre sistemas de control y dispositivos de campo	Muchos fueron diseñados para confianza y disponibilidad, no para adversarios modernos

Tabla 2: Tecnologías centrales para el technical breakdown del informe.

Los protocolos industriales heredados completan el problema. Protocolos como Modbus, DNP3 u OPC clásico fueron diseñados principalmente para confiabilidad, interoperabilidad y continuidad operacional. En muchos despliegues antiguos, no incorporaban autenticación fuerte, cifrado o validación contextual de comandos. Eso no significa que todo uso sea inseguro, pero sí que su seguridad depende de controles compensatorios: segmentación, monitoreo, gateways industriales, listas de control, reglas de acceso y procedimientos operativos.

Esta es la base de la deuda de seguridad OT. Muchos sistemas industriales fueron diseñados bajo el supuesto de que la red era cerrada, los operadores eran confiables y el acceso físico o lógico estaba limitado. Ese supuesto se vuelve

peligroso cuando las redes OT se conectan con redes corporativas, proveedores remotos, servicios de monitoreo o plataformas modernas. NIST SP 800 82 enfatiza que la seguridad OT debe considerar disponibilidad, confiabilidad, seguridad física y continuidad operacional, no solo confidencialidad de datos. [4]

Una tercera tecnología relevante: EternalBlue y el protocolo SMBv1. El relato sobre Shadow Brokers y NotPetya, desarrollado en la sección de casos, se vuelve técnicamente inteligible cuando se examina la pieza concreta que conectó ambos episodios: el exploit *EternalBlue*, atribuido a Equation Group, dirigido contra una vulnerabilidad de corrupción de memoria en el subsistema *Server Message Block versión 1 (SMBv1)* de Windows. [1] SMBv1 es un protocolo de los años ochenta utilizado para compartir archivos e impresoras en redes corporativas; opera sobre el puerto TCP 445 y, hasta Windows 10 Fall Creators Update, venía habilitado por defecto en sistemas operativos masivamente desplegados, incluidos hospitales, oficinas administrativas, estaciones de ingeniería y servidores de planta.

Mecánicamente, EternalBlue explotaba una conversión incorrecta entre estructuras *OS2 FEA* y *NT FEA* en el procesador de paquetes *Srv.sys*, lo que permitía un *buffer overflow* en el pool no paginado del kernel y, finalmente, ejecución remota de código con privilegios SYSTEM. Microsoft publicó el parche MS17 010 en marzo de 2017, un mes antes de que Shadow Brokers liberara públicamente el arsenal. [1] Sin embargo, el parcheo masivo en hospitales, infraestructura crítica y entornos OT no ocurre en treinta días: depende de ventanas de mantenimiento, certificaciones de proveedor y aprobaciones operativas. Esa brecha temporal habilitó WannaCry en mayo de 2017 y NotPetya en junio del mismo año.

Para infraestructura crítica, EternalBlue ilustra dos lecciones complementarias a las de PLCs y HMIs. Primero, los protocolos heredados no son exclusivos del mundo industrial: también existen en redes corporativas que se conectan, directa o indirectamente, con redes OT, y por esa vía un compromiso IT puede transformarse en impacto sobre procesos físicos. Segundo, una vulnerabilidad acumulada por una agencia estatal puede regresar como riesgo doméstico cuando se filtra, lo que conecta el problema técnico con el debate ético sobre *stockpiling* planteado en la sección anterior.

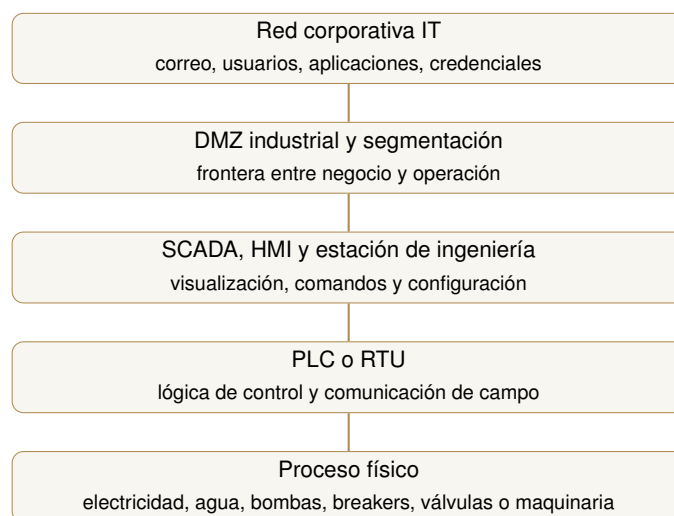


Figura 1: Ruta conceptual desde IT hacia procesos físicos en un entorno OT.

El diagrama muestra por qué la defensa de infraestructura crítica no puede limitarse a proteger endpoints corporativos. La protección debe enfocarse en rutas de acceso, límites entre zonas, privilegios, telemetría industrial y capacidad de recuperación. CISA recomienda segmentación, reducción de exposición y separación de redes industriales frente a redes menos confiables. [5] Estas medidas no eliminan el riesgo, pero reducen la posibilidad de que un compromiso inicial se convierta en impacto físico.

En síntesis, Siemens Step 7 y los PLCs muestran cómo malware puede llegar desde software común hasta controladores industriales. GE Cimplicity y los HMIs muestran cómo la visibilidad del operador puede convertirse en objetivo. EternalBlue y SMBv1 muestran cómo un protocolo IT heredado puede convertirse en vector entre redes corporativas y entornos industriales. Los protocolos heredados y la deuda OT explican por qué proteger infraestructura crítica es más difícil que aplicar parches o instalar herramientas de seguridad. En OT, una falla digital puede convertirse en una falla de seguridad pública.

4. Casos clave: Aurora, Stuxnet, Ucrania, Shadow Brokers y NotPetya

Los casos narrados por Perlroth muestran una progresión clara: las vulnerabilidades primero se convierten en herramientas de espionaje; luego se integran en operaciones estatales; después empiezan a producir efectos físicos; finalmente pueden filtrarse, propagarse y regresar como daño sistémico. Esta sección analiza cinco casos que conectan el mercado de zero days con infraestructura crítica: *Operation Aurora*, Stuxnet, los ataques contra la red eléctrica ucraniana, Shadow Brokers y NotPetya.

Operation Aurora representa el despertar corporativo. El capítulo *Aurora* de Perlroth se refiere principalmente al ataque atribuido a China contra Google y otras empresas tecnológicas. Su importancia para este informe no está en daño físico directo, sino en el cambio institucional que produjo: Google dejó de verse solo como una empresa tecnológica y empezó a actuar como un actor de seguridad con responsabilidades geopolíticas. La intrusión mostró que las grandes plataformas digitales podían ser objetivos de espionaje estatal y que la seguridad corporativa debía incluir protección de usuarios, propiedad intelectual, disidentes y ecosistemas completos. Esa reacción prepara el terreno para iniciativas posteriores como bug bounties, divulgación coordinada y Project Zero, discutidas por Perlroth en *Bounty Hunters*. [1]

Es importante distinguir *Operation Aurora* de la prueba conocida como Aurora Generator Test. La primera aparece en el libro como un caso de espionaje y cambio corporativo. La segunda, realizada en Idaho National Laboratory en 2007, demostró que código malicioso podía dañar físicamente un generador eléctrico. [7] Ambas comparten nombre, pero enseñan lecciones distintas: *Operation Aurora* muestra que el sector privado se volvió parte del conflicto geopolítico digital; Aurora Generator Test muestra que una operación cibernética puede producir daño físico en infraestructura eléctrica.

Stuxnet representa el paso del malware al proceso físico. Perlroth lo presenta como una operación que utilizó vulnerabilidades y conocimiento técnico especializado para afectar centrifugadoras iraníes. El malware buscaba sistemas asociados a Siemens Step 7 y PLCs, lo que permitió conectar una infección digital con controladores industriales que gobernaban equipos físicos. [1] La lección central es que el objetivo final no era simplemente entrar a una computadora, sino manipular la lógica de control de un proceso industrial. Stuxnet mostró que el código podía funcionar como herramienta de sabotaje estatal y abrió una pregunta ética más amplia: si una capacidad de ese tipo se desarrolla, se estudia, se copia o se filtra, puede ser adaptada contra redes eléctricas, plantas de agua, fábricas o sistemas civiles.

Ucrania y The Grid convierten la tesis en evidencia histórica. En el prólogo, Perlroth presenta a Ucrania como un laboratorio de agresión digital rusa. Tras la revolución de 2014, el país fue sometido a espionaje, desinformación, intrusiones, sabotaje y ataques contra servicios esenciales. El ataque del 23 de diciembre de 2015 contra la red eléctrica ucraniana fue un hito: los atacantes se habían insertado en estaciones eléctricas, entraron a computadoras que controlaban la red y apagaron circuit breakers hasta dejar sin electricidad a cientos de miles de personas. También afectaron líneas de emergencia y respaldo eléctrico en centros de distribución. [1] CISA documentó el ataque y reportó el uso de malware destructivo como KillDisk, mientras MITRE lo asocia con Sandworm Team, BlackEnergy3 y KillDisk. [8, 9] El objetivo no era robar dinero, sino demostrar que un adversario podía afectar directamente la vida cotidiana de una población civil mediante sistemas digitales.

Shadow Brokers representa el colapso de la premisa de control. Perlroth describe la filtración de herramientas asociadas a la NSA como un punto de inflexión porque redujo la distancia entre capacidades ofensivas estatales y capacidades disponibles para otros actores. [1] Este caso conecta directamente con el problema del *stockpiling*: una agencia puede justificar la retención de vulnerabilidades por inteligencia o seguridad nacional, pero esa decisión depende de que las herramientas permanezcan secretas. Shadow Brokers mostró que esa garantía no existe. Cuando un arsenal se filtra, el riesgo deja de estar limitado al adversario previsto y puede alcanzar empresas, gobiernos locales, hospitales, infraestructura crítica y usuarios comunes.

NotPetya muestra el efecto boomerang de la militarización del código. En junio de 2017, un ataque dirigido contra Ucrania se propagó más allá del contexto inicial y afectó empresas globales, logística, farmacéuticas, transporte, sistemas de pago, estaciones de gasolina, cajeros automáticos y monitoreo de radiación en Chernobyl, según el relato de Perlroth. [1] Aunque inicialmente parecía ransomware, NotPetya fue diseñado como malware destructivo: el mensaje de pago ocultaba que las víctimas no podían recuperar sus sistemas simplemente pagando. Wired lo describió como uno de los ciberataques más devastadores de la historia y reportó daños globales superiores a 10 mil millones de dólares. [10] El caso destruye la idea de que una operación cibernética puede mantenerse contenida geográficamente: un ataque regional puede convertirse en crisis corporativa y económica internacional.

Caso	Lección técnica	Lección socio política
Operation Aurora	Empresas tecnológicas pueden ser objetivos de espionaje avanzado	El sector privado se convierte en actor de seguridad geopolítica
Aurora Generator Test	Código puede producir daño físico en equipos eléctricos	La infraestructura conectada debe tratarse como riesgo de seguridad pública
Stuxnet	Malware puede manipular PLCs y procesos físicos	El código puede funcionar como herramienta de sabotaje estatal
Ucrania 2015 y 2016	Intrusiones digitales pueden afectar redes eléctricas	La infraestructura civil puede usarse como presión política
Shadow Brokers	Herramientas ofensivas pueden filtrarse y reutilizarse	El stockpiling puede regresar como riesgo sistémico
NotPetya	Malware destructivo puede propagarse globalmente	Un ataque regional puede producir daño económico y social internacional

Tabla 3: Síntesis de los casos principales y su aporte al argumento del informe.

En conjunto, estos casos sostienen la tesis central. *Operation Aurora* muestra que las empresas tecnológicas entraron en la geopolítica de la seguridad. *Aurora Generator Test* y *Stuxnet* muestran que el código puede cruzar del mundo digital al físico. *Ucrania* muestra que una red eléctrica puede convertirse en instrumento de coerción. *Shadow Brokers* muestra que las herramientas ofensivas no permanecen necesariamente bajo control. *NotPetya* muestra que un ataque dirigido puede convertirse en crisis global. La lección común es que la militarización del código no puede evaluarse solo por su utilidad ofensiva; debe evaluarse por su riesgo de filtración, propagación, reutilización y daño civil.

Síntesis diagnóstica: las seis capas de la deuda de seguridad. Los casos analizados, leídos en conjunto, no muestran fallas aisladas sino una arquitectura de fragilidad acumulada durante décadas. La fragilidad documentada por Perlroth puede organizarse en seis capas, donde cada una se sostiene en una decisión racional de corto plazo cuyo costo agregado se traduce en superficie de ataque sistémica.

#	Capa	Evidencia derivada del libro
1	Diseño	Sistemas <i>built for access, not security</i> : protocolos como Modbus, DNP3 y S7 fueron concebidos para disponibilidad y telemetría, no para adversarios estatales con acceso de red. [1]
2	Software	Hospitales y utilities operando Windows XP después del fin de soporte en 2014, junto con estaciones de ingeniería con versiones legadas de software industrial. [1]
3	Parches	La automatización de actualizaciones está restringida en redes industriales por riesgo de interrumpir procesos físicos; las ventanas de mantenimiento ocurren una o dos veces al año. [1]
4	Cadena de suministro	Actualizaciones legítimas troyanizadas: M.E. Doc en NotPetya y archivos asociados a GE Cimplicity en operaciones de Sandworm. El proveedor de confianza se convierte en vector. [1]
5	Regulación	La presión de lobbies diluyó estándares federales hasta volverlos voluntarios; la regulación obligatoria suele llegar solo después de incidentes con impacto público visible. [1]
6	Atribución y disuasión	La capacidad ofensiva no se traduce automáticamente en disuasión: los adversarios siguen operando porque la atribución pública es lenta y las consecuencias suelen ser limitadas. [1]

Tabla 4: Las seis capas de la deuda de seguridad en infraestructura crítica.

A estas seis capas se suma una dinámica transversal: el efecto bumerán. *EternalBlue*, retenido por una agencia estatal, fue robado, filtrado y reutilizado para *WannaCry* y *NotPetya*, generando daños globales estimados en diez mil millones de dólares según el ex asesor de seguridad nacional Tom Bossert. [1, 10] Esta secuencia es la confirmación empírica de que la acumulación de vulnerabilidades no es una decisión moralmente neutra: el cálculo de utilidad ofensiva debe restar el daño esperado por filtración, particularmente cuando la falla afecta software desplegado en infraestructura civil. La síntesis prepara la transición hacia la sección de impacto social: una arquitectura técnica frágil multiplica sus consecuencias cuando se cruza con servicios esenciales y dependencia ciudadana.

5. Societal Impact: ley, percepción pública y comportamiento corporativo

Los casos analizados por Perlroth cambiaron la forma en que gobiernos, empresas y ciudadanos entienden la ciberseguridad. Antes, muchos incidentes digitales se interpretaban como problemas de privacidad, robo de datos o fraude financiero. Después de Aurora, Stuxnet, Ucrania, Shadow Brokers y NotPetya, el riesgo cibernético empezó a verse como una cuestión de seguridad pública, continuidad económica y estabilidad geopolítica. La lección social es clara: cuando el software sostiene electricidad, agua, transporte, salud y logística, una falla digital puede afectar la vida cotidiana.

El primer cambio ocurrió en la percepción pública. Ucrania mostró que una red eléctrica podía ser interrumpida por medios digitales y usada como mensaje político. NotPetya mostró que un ataque dirigido contra un país podía afectar empresas globales, cadenas logísticas, farmacéuticas y servicios civiles. Shadow Brokers mostró que las herramientas ofensivas de un Estado podían escapar de su control. En conjunto, estos casos desplazaron la conversación: la ciberseguridad dejó de ser solo protección de computadoras y pasó a ser protección de servicios esenciales.

El segundo cambio fue institucional. NIST CSF 2.0 refleja esta evolución al incluir la función *Govern*, orientada a establecer, comunicar y monitorear estrategia, expectativas y política de riesgo cibernético. [11] Esta función es relevante porque reconoce que la ciberseguridad no puede depender únicamente de equipos técnicos. Debe integrarse en decisiones ejecutivas, gestión de riesgo, supervisión organizacional y responsabilidad institucional. La SEC también adoptó reglas que exigen a compañías públicas divulgar incidentes materiales de ciberseguridad y describir procesos de gestión de riesgo, estrategia y gobierno corporativo. [12] En infraestructura crítica, CIRCIA apunta hacia reporte obligatorio de incidentes relevantes y pagos de ransomware por parte de entidades cubiertas, para mejorar visibilidad nacional y coordinación defensiva. [13]

El tercer cambio ocurrió dentro de las empresas. *Operation Aurora* obligó a Google y a otras compañías tecnológicas a reconocer que ya no eran simples negocios privados, sino actores dentro de un conflicto geopolítico digital. La respuesta corporativa posterior incluyó mayor inversión defensiva, programas de recompensas por vulnerabilidades, divulgación coordinada y una postura más activa frente a fallas usadas por actores estatales. NotPetya produjo un cambio distinto: para empresas industriales, logísticas y farmacéuticas, la pregunta dejó de ser únicamente cómo impedir una intrusión y pasó a ser cómo continuar operando cuando una intrusión ya ocurrió.

Dimensión social	Cambio observado	Evidencia o consecuencia
Percepción pública	De ciberseguridad como problema técnico a ciberseguridad como continuidad social	Ucrania y NotPetya muestran efectos sobre electricidad, logística, pagos y servicios civiles
Ley y política pública	Mayor énfasis en gobernanza, reporte y gestión de riesgo	NIST CSF 2.0, SEC cyber disclosure y CIRCIA elevan la responsabilidad institucional
Comportamiento corporativo	De prevención aislada a resiliencia operacional	Aurora impulsa seguridad de producto; NotPetya refuerza backups, segmentación, proveedores y continuidad
Gestión de vulnerabilidades	De valor ofensivo a evaluación de daño sistémico	El debate sobre disclosure y VEP conecta la falla técnica con exposición civil
Infraestructura crítica	De operación técnica especializada a prioridad de seguridad pública	OT, ICS y redes eléctricas requieren coordinación entre empresas, gobierno y operadores

Tabla 5: Impactos sociales e institucionales derivados de los casos estudiados.

En síntesis, los eventos analizados cambiaron tres dimensiones: ley y política pública, percepción pública y comportamiento corporativo. La ciberseguridad pasó de ser una función técnica a convertirse en una responsabilidad institucional y cívica. Esta transformación prepara la necesidad de un marco de *Responsible Active Defense*: una defensa proactiva, pero limitada por responsabilidad legal, proporcionalidad y protección civil.

6. Policy Framework: Responsible Active Defense

Los casos analizados muestran que la infraestructura crítica no puede defenderse con una postura puramente pasiva. Aurora, Stuxnet, Ucrania, Shadow Brokers y NotPetya demuestran que una intrusión digital puede convertirse en espionaje, manipulación física, interrupción de servicios, daño económico o pérdida de confianza pública. Sin embargo, responder a esa amenaza no significa permitir represalias privadas ni normalizar que empresas ataquen

sistemas externos. Por eso, este informe propone un marco de *Responsible Active Defense*: una defensa proactiva, autorizada, auditable y centrada en continuidad de servicios esenciales.

En este marco, *Active Defense* no significa *hack back*. Una empresa eléctrica, una planta de agua, un hospital o un operador logístico no deberían responder a una intrusión atacando infraestructura ajena. Esa práctica puede producir errores de atribución, afectar a terceros inocentes, interferir con investigaciones oficiales y escalar conflictos internacionales. La defensa activa responsable debe limitarse a redes propias, sistemas autorizados, coordinación con autoridades y medidas de resiliencia operacional.

La defensa activa responsable no busca castigar al atacante. Busca detectar antes, limitar movimiento lateral, preservar servicios esenciales, coordinar respuesta y recuperar operación antes de que una intrusión se convierta en crisis pública.

El marco se organiza en seis pilares alineados con NIST Cybersecurity Framework 2.0: gobernar, identificar, proteger, detectar, responder y recuperar. [11] Esta estructura evita tratar la defensa activa como una herramienta aislada. La convierte en un ciclo de gestión de riesgo que involucra liderazgo ejecutivo, equipos técnicos, operadores industriales, proveedores, reguladores y autoridades públicas.

Pilar	Objetivo	Aplicación en infraestructura crítica
Govern	Definir autoridad, responsabilidades y riesgo aceptable	Supervisión ejecutiva, políticas OT, roles claros y criterios de escalamiento
Identify	Conocer activos, dependencias y criticidad	Inventario IT/OT, mapas de comunicación, proveedores, accesos remotos y procesos esenciales
Protect	Reducir superficie de ataque	Segmentación IT/OT, MFA, mínimo privilegio, hardening, control de proveedores y acceso remoto seguro
Detect	Encontrar actividad anómala temprano	Monitoreo OT, threat hunting, detección de cambios no autorizados y alertas sobre comportamiento industrial
Respond	Contener y coordinar durante el incidente	Aislamiento de segmentos, comunicación ejecutiva, reporte a autoridades y análisis forense
Recover	Restaurar continuidad operacional	Backups offline, operación manual, pruebas de recuperación y lecciones aprendidas

Tabla 6: Marco de Responsible Active Defense alineado con NIST CSF 2.0.

El primer principio práctico es la segmentación IT/OT. Muchos ataques contra infraestructura no comienzan en el PLC ni en el sistema SCADA, sino en correo electrónico, credenciales, VPNs, accesos de proveedores o redes corporativas. Por eso, CISA recomienda separar redes industriales de redes menos confiables, reducir exposición y usar zonas de seguridad para limitar rutas hacia sistemas críticos. [5] La segmentación no elimina el riesgo, pero reduce la probabilidad de que un compromiso inicial se convierta en impacto físico.

El segundo principio es visibilidad operacional. Una organización no puede defender activos que no conoce. La defensa activa requiere inventario de PLCs, HMIs, estaciones de ingeniería, servidores SCADA, RTUs, gateways, conexiones remotas y rutas entre zonas de red. También requiere monitoreo de tráfico OT y detección de cambios inusuales en lógica de control, comunicaciones industriales o acceso a estaciones de ingeniería. En infraestructura crítica, detectar temprano puede marcar la diferencia entre un incidente contenido y una interrupción de servicios esenciales.

El tercer principio es respuesta coordinada. Durante un incidente OT, una mala decisión técnica puede afectar operación física. Por eso, la respuesta debe incluir ciberseguridad, ingeniería, operaciones, legal, comunicación y liderazgo ejecutivo. También debe coordinarse con autoridades, CERTs sectoriales, proveedores y reguladores cuando corresponda. CIRCIA refuerza esta lógica al orientar el reporte de incidentes relevantes y pagos de ransomware por parte de entidades cubiertas, con el fin de mejorar visibilidad nacional y coordinación defensiva. [13]

El cuarto principio es recuperación operacional. NotPetya mostró que el daño destructivo puede propagarse con gran velocidad. Por eso, la recuperación no puede improvisarse. Los operadores de infraestructura crítica necesitan respaldos offline, imágenes limpias de sistemas críticos, procedimientos manuales, simulacros de apagón, pruebas de

restauración y planes de operación degradada. En OT, recuperarse no significa solo reinstalar software; significa restablecer procesos físicos de forma segura.

El quinto principio es gestión responsable de vulnerabilidades. Cuando una falla afecta infraestructura crítica, productos ampliamente usados o sistemas que sostienen servicios esenciales, la presunción ética debe favorecer la divulgación responsable. El *Vulnerabilities Equities Process* ofrece una base para evaluar si una vulnerabilidad debe divulgarse o retenerse temporalmente por razones excepcionales. [2] Para infraestructura crítica, la retención debe ser limitada, revisada periódicamente y justificada por necesidad, proporcionalidad y control efectivo.

También debe diferenciarse defensa civil de operaciones estatales. Estrategias como *defend forward*, mencionadas por el Departamento de Defensa de Estados Unidos, pertenecen al ámbito estatal y militar, no a la respuesta privada de operadores civiles. [14] Una política responsable puede reconocer la necesidad de capacidades estatales, pero no debe delegar represalias digitales en empresas privadas.

Cinco pilares políticos complementarios al marco operativo. El marco NIST CSF 2.0 estructura la defensa al interior de la organización, pero no resuelve por sí solo los incentivos sistémicos que el libro identifica. A continuación se proponen cinco pilares políticos, deducidos directamente de problemas que Perlroth documenta, que complementan los seis pilares operacionales anteriores.

#	Pilar político	Justificación derivada del libro
1	Estándares federales obligatorios para infraestructura crítica	Los estándares voluntarios fracasaron tras la presión de lobbies; la regulación obligatoria es la herramienta normal para internalizar externalidades de gran magnitud. [1]
2	VEP con sesgo de divulgación para software civil	El bumerán de EternalBlue demuestra que las vulnerabilidades acumuladas fugan; en software desplegado en salud, agua o energía civil, la presunción ética debe favorecer la divulgación responsable. [2]
3	Convención Digital de Ginebra	Recogiendo la propuesta de Brad Smith, una norma internacional que excluya hospitales, redes eléctricas y servicios civiles esenciales como blancos legítimos crea costos reputacionales para quienes la violan. [1]
4	Defensa activa con líneas rojas codificadas	Tres condiciones operativas: proporcionalidad sustentada en alta confianza de atribución, exclusión de objetivos civiles, y supervisión legislativa real sobre operaciones ciber ofensivas, incluso cuando la cadena de mando se considere poco fiable. [14]
5	Resiliencia y <i>manual play</i>	Ejercicios obligatorios de operación manual, reservas estratégicas de transformadores intercambiables, <i>air gap</i> físico real para sistemas de seguridad de represas, plantas nucleares y potabilización, y <i>bug bounties</i> obligatorios para operadores de infraestructura crítica. [5, 4]

Tabla 7: Pilares políticos complementarios al marco operativo de defensa activa.

Estos cinco pilares no resuelven el problema en una década, pero rompen la inercia que el libro documenta: incentivos privados que no internalizan el costo social de la inseguridad, agencias que acumulan vulnerabilidades sin restar el costo esperado del bumerán, y operadores de infraestructura sin recursos comparables a los de los grandes distribuidores. La combinación entre el marco operativo, alineado con NIST CSF 2.0, y el marco político, deducido del libro, es lo que define la diferencia entre defensa activa responsable y carrera ofensiva sin control.

Un marco de Active Defense sin límites puede convertirse en privatización de la guerra cibernética. Un marco demasiado pasivo deja a la sociedad esperando el próximo apagón. La respuesta defendible es una defensa proactiva, autorizada, auditable y centrada en continuidad de servicios esenciales.

En conclusión, *Responsible Active Defense* no es una estrategia de agresión. Es una política de reducción de daño. Su objetivo es impedir que una intrusión técnica se convierta en apagón, interrupción de agua, crisis hospitalaria, daño logístico o pérdida de confianza pública. Las lecciones de Perlroth apuntan a una misma dirección: si el mercado de zero days y la militarización del código aumentan el riesgo sistémico, la respuesta ética no debe ser más opacidad ni represalia privada, sino visibilidad, coordinación, resiliencia y límites claros.

7. Personal Critique: ética profesional en InfoSec

La lectura de *This Is How They Tell Me the World Ends* nos obliga a ver la ciberseguridad como una disciplina de consecuencias, no solo de habilidad técnica. Perlroth muestra que una vulnerabilidad puede comenzar como un error de software, pero terminar como mercancía, secreto estatal, herramienta de vigilancia o capacidad de sabotaje. Por eso, nuestra reflexión ética se divide en tres posturas personales.

Roberto. Mi principal cambio ético surge del mercado de zero days. Antes podía entender una vulnerabilidad como un hallazgo técnico cuyo valor dependía de su dificultad, rareza o utilidad. Después de leer a Perlroth, la veo como una decisión moral: reportarla, venderla o guardarla cambia quién queda protegido y quién queda expuesto. La escena de *The Fucking Salmon* me hizo cuestionar la comodidad con la que algunos actores separan el exploit de sus consecuencias. Como futuro profesional de InfoSec, no quiero medir el éxito solo por encontrar fallas, sino por reducir el daño que esas fallas podrían causar si llegan a compradores irresponsables.

Pablo. Mi reflexión se centra en infraestructura crítica. El análisis de PLCs, HMIs y sistemas OT me hizo ver que no todos los sistemas tienen el mismo nivel de consecuencia. En IT, una falla puede exponer datos; en OT, puede afectar electricidad, agua, maquinaria, transporte o seguridad física. Esto cambia mi ética profesional porque me obliga a pensar antes de intervenir. No basta con aplicar controles genéricos ni asumir que todo se resuelve con parches. En infraestructura crítica, defender bien exige entender el proceso físico, hablar con operadores y priorizar continuidad y seguridad humana sobre demostraciones de habilidad técnica.

Andrés. Mi mayor aprendizaje viene de Ucrania, Shadow Brokers, NotPetya y la discusión sobre Active Defense. Estos casos muestran que las operaciones cibernéticas no permanecen dentro de límites limpios. Una herramienta retenida puede filtrarse; un ataque dirigido puede expandirse; una decisión ofensiva puede afectar a civiles y empresas que no eran el objetivo. El bumerán de EternalBlue me convenció de que la acumulación de vulnerabilidades por una agencia estatal no es una decisión moralmente neutra: el cálculo de utilidad ofensiva debe restar el daño esperado por filtración. Por eso, mi postura ética frente a Active Defense es clara: defensa activa no debe significar represalia. Debe significar detectar antes, segmentar mejor, coordinar con autoridades, divulgar responsablemente cuando la falla afecta software civil y recuperar servicios esenciales. Para mí, el éxito profesional en InfoSec debe medirse por la capacidad de evitar crisis sociales, no por atacar de vuelta.

Nuestra conclusión común es que la ciberseguridad profesional debe medirse por reducción de daño. Cuando una vulnerabilidad puede afectar infraestructura civil, la decisión ética correcta debe priorizar divulgación responsable, resiliencia operacional y protección de la población.

En conjunto, el libro desplaza nuestra ética desde la fascinación por la capacidad ofensiva hacia una responsabilidad pública. La habilidad técnica sigue siendo importante, pero no es suficiente. Si el software sostiene electricidad, agua, salud, transporte y confianza social, entonces cada decisión sobre vulnerabilidades debe evaluarse por sus consecuencias para las personas que dependen de esos sistemas.

8. Conclusión

This Is How They Tell Me the World Ends muestra que la ciberseguridad contemporánea no puede separarse de la política, la economía ni la infraestructura civil. Nicole Perlroth presenta un ecosistema donde los zero days dejan de ser simples errores técnicos y se convierten en mercancías, secretos estatales y capacidades ofensivas. Cuando esas capacidades se cruzan con sistemas industriales heredados, redes eléctricas, plantas de agua, hospitales, transporte y cadenas logísticas, la vulnerabilidad deja de ser un problema privado de software y se convierte en riesgo público.

La tesis del informe es que la infraestructura crítica se convierte en campo de batalla cuando coinciden tres fuerzas: un mercado que premia mantener vulnerabilidades en secreto, una lógica estatal que valora capacidades ofensivas y una base industrial diseñada para continuidad y confianza, no para adversarios avanzados. Los casos analizados confirman esa progresión: *Operation Aurora* muestra el despertar corporativo, Stuxnet conecta malware con procesos físicos, Ucrania evidencia coerción contra infraestructura civil, Shadow Brokers revela el riesgo de perder control sobre arsenales digitales y NotPetya demuestra que un ataque regional puede convertirse en crisis global.

La respuesta propuesta no es una escalada ofensiva ni la privatización de la guerra cibernética. El marco de *Responsible Active Defense* rechaza el *hack back* privado y propone una defensa proactiva dentro de redes autorizadas: gobernanza, inventario de activos, segmentación IT/OT, monitoreo OT, detección temprana, divulgación responsable, coordinación público privada y recuperación operacional. Su objetivo es reducir daño, preservar continuidad y evitar que una intrusión técnica se transforme en crisis pública.

La conclusión ética es que la ciberseguridad debe medirse por sus consecuencias. Encontrar una vulnerabilidad no es

el final del trabajo profesional, sino el inicio de una decisión moral sobre divulgación, uso, retención o explotación. En infraestructura crítica, esa decisión puede afectar electricidad, agua, salud, transporte y confianza social. Por eso, el profesional de InfoSec no debe definirse solo por su capacidad ofensiva, sino por su criterio para proteger a quienes dependen de los sistemas que defiende.

La infraestructura crítica no debe convertirse en el laboratorio de una carrera de ciberarmas. Si el software sostiene la vida moderna, protegerlo no es solo una tarea técnica: es una responsabilidad pública.

Referencias

- [1] Perlroth, N. (2021). *This Is How They Tell Me the World Ends: The Cyberweapons Arms Race*. Bloomsbury Publishing.
- [2] The White House. (2017). *Vulnerabilities Equities Policy and Process for the United States Government*. Executive Office of the President. Disponible en: <https://trumpwhitehouse.archives.gov/sites/whitehouse.gov/files/images/External%20-%20Unclassified%20VEP%20Charter%20FINAL.PDF>
- [3] Cybersecurity and Infrastructure Security Agency. (n.d.). *Industrial Control Systems*. U.S. Department of Homeland Security. Disponible en: <https://www.cisa.gov/topics/industrial-control-systems>
- [4] Stouffer, K., Pease, M., Tang, C., Zimmerman, T., Pillitteri, V., Lightman, S., Hahn, A., Saravia, S., Sherule, A., & Thompson, M. (2023). *Guide to Operational Technology (OT) Security, NIST Special Publication 800 82 Revision 3*. National Institute of Standards and Technology. Disponible en: <https://doi.org/10.6028/NIST.SP.800-82r3>
- [5] Cybersecurity and Infrastructure Security Agency. (n.d.). *Cybersecurity Best Practices for Industrial Control Systems*. U.S. Department of Homeland Security. Disponible en: https://www.cisa.gov/sites/default/files/publications/Cybersecurity_Best_Practices_for_Industrial_Control_Systems_508.pdf
- [6] MITRE. (n.d.). *Lateral Movement, Tactic TA0109: ICS*. MITRE ATT&CK for ICS. Disponible en: <https://attack.mitre.org/tactics/TA0109/>
- [7] Greenberg, A. (2020). *How 30 Lines of Code Blew Up a 27 Ton Generator*. Wired. Disponible en: <https://www.wired.com/story/how-30-lines-of-code-blew-up-27-ton-generator/>
- [8] Cybersecurity and Infrastructure Security Agency. (2021). *Cyber Attack Against Ukrainian Critical Infrastructure*. U.S. Department of Homeland Security. Disponible en: <https://www.cisa.gov/news-events/ics-alerts/ir-alert-h-16-056-01>
- [9] MITRE. (2023). *2015 Ukraine Electric Power Attack, Campaign C0028*. MITRE ATT&CK. Disponible en: <https://attack.mitre.org/campaigns/C0028/>
- [10] Greenberg, A. (2018). *The Untold Story of NotPetya, the Most Devastating Cyberattack in History*. Wired. Disponible en: <https://www.wired.com/story/notpetya-cyberattack-ukraine-russia-code-crashed-the-world/>
- [11] National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. National Institute of Standards and Technology. Disponible en: <https://doi.org/10.6028/NIST.CSWP.29>
- [12] U.S. Securities and Exchange Commission. (2023). *Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure*. Securities and Exchange Commission. Disponible en: <https://www.sec.gov/files/rules/final/2023/33-11216.pdf>
- [13] Cybersecurity and Infrastructure Security Agency. (n.d.). *Cyber Incident Reporting for Critical Infrastructure Act, Frequently Asked Questions*. U.S. Department of Homeland Security. Disponible en: <https://www.cisa.gov/topics/cyber-threats-and-advisories/information-sharing/circia/faqs>
- [14] U.S. Department of Defense. (2023). *2023 Department of Defense Cyber Strategy Summary*. Disponible en: https://media.defense.gov/2023/Sep/12/2003299076/-1/-1/1/2023_DOD_Cyber_Strategy_Summary.pdf